

❏ 1. Denial of Service (DoS)

What is DoS?

A Denial of Service (DoS) attack attempts to make a machine, service, or network resource unavailable by overwhelming it with traffic or exploiting software flaws.

Types of DoS Attacks:

Volume-Based Attacks:

Example: UDP flood, ICMP flood, Ping of Death.

Goal: Exhaust bandwidth.

Protocol Attacks:

Example: SYN Flood, Smurf attack.

Goal: Exhaust server resources like connection tables.

Application Layer Attacks:

Example: HTTP Flood.

Goal: Crash or slow down a specific application.

Distributed Denial of Service (DDoS):

An advanced version of DoS where the attack comes from multiple systems (often a botnet) simultaneously.

Consequences:

Website downtime.

Financial and reputation loss.

Loss of user trust.

Mitigation:

Rate Limiting: Controls traffic from a user/IP.

Firewalls and Intrusion Detection Systems.

CDNs and Anti-DDoS Services (Cloudflare, AWS Shield).

Redundancy and Failover Systems.

2. Buffer Overflows and Input Validation

Buffer Overflow:

Occurs when a program writes more data to a memory buffer than it can hold, overwriting adjacent memory.

How It Works:

```
c
Copy
Edit
char buffer[10];
strcpy(buffer, "this string is way too long");
This overwrites memory and can be used to:
```

Crash the system.

Inject and execute malicious code (e.g., shellcode).

Escalate privileges.

Exploitation Example:

Injecting malicious machine code into memory and redirecting execution to it using overwritten return addresses.

Prevention Techniques:

Bounds Checking: Always verify buffer size.

Safe Functions: Use strncpy instead of strcpy.

Stack Canaries: Extra values placed before return pointers to detect overflow.

Address Space Layout Randomization (ASLR).

Non-executable stack (DEP - Data Execution Prevention).

Input Validation:

Ensuring that user input is:

Of expected type (e.g., integer, string).

Of expected length.

Free from dangerous characters (e.g., <, ', ").

Common Vulnerabilities Due to Poor Validation:

SQL Injection

Command Injection

XSS

Buffer Overflow

Best Practices:

Whitelist over blacklist.

Use built-in sanitization functions.

Apply encoding and escaping where necessary.

Client-side + Server-side validation.

3. Access Control

What is Access Control?

It determines what users can do within a system: what they can read, write, or modify.

Types of Access Control:

Discretionary Access Control (DAC)

Owner decides who has access.

Example: Linux file permissions (chmod).

Mandatory Access Control (MAC)

Enforced by the system based on labels (e.g., "Top Secret").

Example: Military systems.

Role-Based Access Control (RBAC)

Permissions are assigned to roles (e.g., Admin, Manager), and users are assigned roles.

Most common in enterprise applications.

Attribute-Based Access Control (ABAC)

Access based on attributes (e.g., time of day, IP, user role).

Highly flexible and dynamic.

Common Vulnerabilities:
Broken Access Control:

Users accessing things they shouldn't.

Examples:

Forced browsing (guessing URLs).

Insecure IDOR (Insecure Direct Object Reference).

Horizontal Privilege Escalation:

Accessing peer-level resources (e.g., another user's account info).

Vertical Privilege Escalation:

Gaining higher-level access (e.g., user becomes admin).

Mitigation Techniques:

Implement server-side authorization checks.

Follow Principle of Least Privilege (PoLP).

Use centralized access control logic.

Log and monitor access control failures.